
Product Security Capability and Maturity Framework:

*A framework for assessing the cybersecurity
maturity of a secure product design program*

Matt Hillyer
*Product Security
Leader*

Document Revision History

Revision	Date	Reason for Change	Author
1.0	May 25, 2025	Initial Release	Matt Hillyer
2.0	March 15, 2026	V2.0 Update	Matt Hillyer

Table of Contents

Capability and Maturity Framework.....	4
1. Purpose	4
2. Benefits	4
3. Scope	5
4. Structure.....	5
Ad Hoc (Level 1)	6
Basic (Level 2).....	6
Defined (Level 3)	7
Managed (Level 4)	7
Optimized (Level 5)	7
5. Domains	7
<i>Secure Design</i>	8
Secure Development.....	8
Security Testing.....	8
Risk Management	9
Privacy & Data Protection	9
Lifecycle Management	9
6. Functions.....	9
6.1. Secure Design	10
6.2. Secure Development	18
6.3. Security Testing	24
6.4. Risk Management	30
6.5. Privacy & Data Protection.....	37
6.6. Lifecycle Management	45

Product Security Capability and Maturity Framework

Capability and Maturity Framework

The Product Security Capability and Maturity Framework is a structured framework designed to assess the secure by design capabilities of an organization throughout the total product lifecycle. This framework involves evaluating existing security practices, reviewing processes and documentation, and identifying processes in need of improvement and maturation.

Organizations can improve their security capabilities by systematically progressing through the defined maturity levels, ultimately achieving optimized and resilient security processes. At the initial levels, teams focus on establishing fundamental security practices and managing incidents reactively. As teams advance, they adopt standardized and proactive security measures, such as incorporating security requirements during the design phase, implementing secure coding practices, and conducting regular vulnerability assessments.

Higher maturity levels emphasize the use of quantitative metrics to manage Secure by Design processes and foster continuous improvement through innovative security solutions. By utilizing the framework, organizations can ensure that security is deeply integrated into their processes, leading to the development and maintenance of secure, reliable, and compliant medical devices capable of withstanding evolving cyber threats throughout the product lifecycle.

1. Purpose

The Capability and Maturity Framework is a systematic tool that enables organizations to assess and understand the current maturity and capabilities of their Secure by Design program. By using this framework, organizations can:

1. Identify specific areas where resources and attention are needed to strengthen security practices and improve overall maturity.
2. Quantitatively measure and track the effectiveness of improvement activities over time.
3. Gain a comprehensive overview of organizational capabilities, supporting informed decision-making and strategic planning for secure by design initiatives.

This clarity empowers organizations to focus their efforts, allocate resources efficiently, and continuously advance their Secure by Design maturity.

2. Benefits

Implementing a Capability and Maturity Framework for engineering organizations offers several benefits:

- **Improved Security Posture:** By systematically evaluating and improving security processes, engineering organizations can better protect their products from security threats and vulnerabilities.
- **Compliance:** Achieving higher maturity levels can help ensure compliance with industry standards and regulatory requirements.
- **Efficiency:** Standardized and optimized processes lead to more efficient product development and reduced time to market.
- **Reputation:** Enhanced security practices contribute to the organization's reputation as a trusted and reliable provider of medical devices.

3. Scope

The Product Security Capability and Maturity Framework is intended to assess the maturity and capability of all processes, standards, and activities that support an entire product lifecycle, from concept and design, through development, deployment, sustainment, and end-of-life. The framework specifically focuses on evaluating Secure by Design practices and methodologies, rather than assessing individual products themselves.

When conducting assessments, the focus should be on the processes involved in designing, developing, manufacturing, and supporting products, as implemented by the organization. Assessment should consider both the application of these processes throughout the product lifecycle and any related support functions, such as data management, both within product design and in the collection and management of data from customers and devices in the design or support of these products.

Additionally, the scope recognizes that relevant processes and capabilities may extend beyond engineering teams to other functions within the division or the broader organization. These activities should also be included in the assessment.

4. Structure

The Product Security Capability and Maturity Framework is structured into 5 levels of maturity, where each level represents a degree of formality and optimization of processes, from ad-hoc and chaotic practices to well-defined and continuously improved and optimized processes.

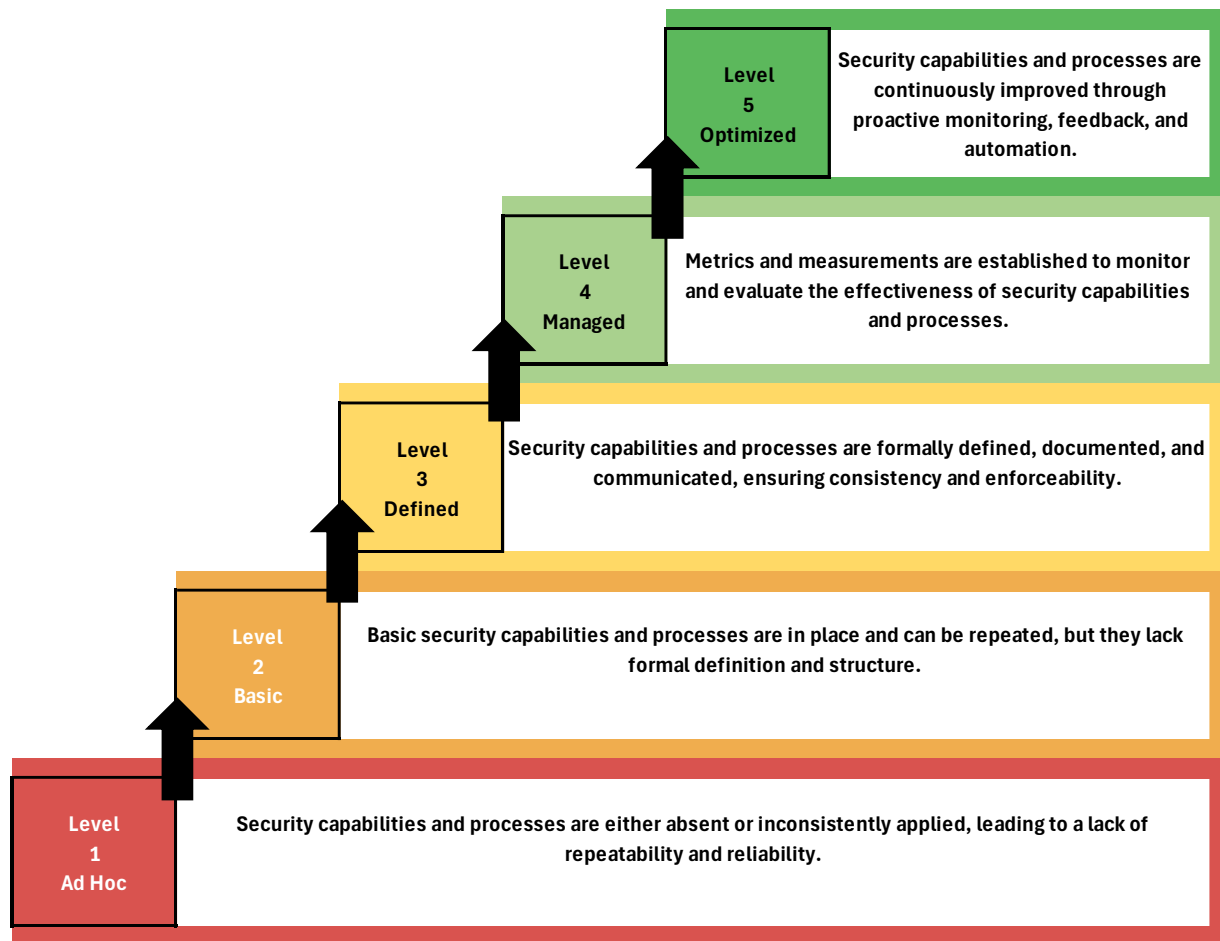


Figure 1: The 5 maturity levels

Ad Hoc (Level 1)

Security capabilities and processes are either absent or inconsistently applied, leading to a lack of repeatability and reliability.

- Initial efforts are made to address the intent of the practice area but lack comprehensiveness.
- Practices are incomplete and do not fully meet the goals of the function.
- Begins to address issues but in an unstructured manner.

Basic (Level 2)

Basic security capabilities and processes are in place and can be repeated, but they lack formal definition and structure.

- Incorporates elements from the Ad Hoc level.

- Practices are simple yet complete enough to meet the basic intent of the function.
- Does not rely heavily on organizational resources.
- Teams begin to identify and monitor progress towards achieving objectives.

Defined (Level 3)

Security capabilities and processes are formally defined, documented, and communicated, ensuring consistency and enforceability.

- Builds upon the practices established at the Basic level.
- Utilizes organizational standards and customizes them to fit specific needs.
- Projects utilize and contribute to organizational resources and assets.
- Focuses on achieving both project-specific and organizational objectives.

Managed (Level 4)

Metrics and measurements are established to monitor and evaluate the effectiveness of security capabilities and processes.

- Builds on the practices established at the Defined level.
- Employs statistical and quantitative techniques to understand performance variations and to detect, refine, or predict areas requiring focus.
- Identifies, understands, and predicts variations, enhancing the ability to achieve Quality and Process Performance Objectives (QPPOs).

Optimized (Level 5)

Security capabilities and processes are continuously improved through proactive monitoring, feedback, and automation.

- Builds on the practices established at the Managed level.
- Utilizes advanced statistical and quantitative techniques to optimize performance and drive continuous improvement.
- Focuses on achieving and surpassing QPPOs through ongoing refinement and innovation.

5. Domains

Within the Product Security Capability and Maturity Framework, a domain represents a key area of focus that includes specific processes, practices, and capabilities vital for ensuring comprehensive product security through Secure by Design methodology over the total product lifecycle. Each domain covers essential aspects of product security and plays a significant role in enhancing the overall maturity and strength of the engineering organization's security posture. Within each

domain, there are various functions. Functions contain the specific activities that characterize the domain. Detailed descriptions are in the *Functions* section of this document.

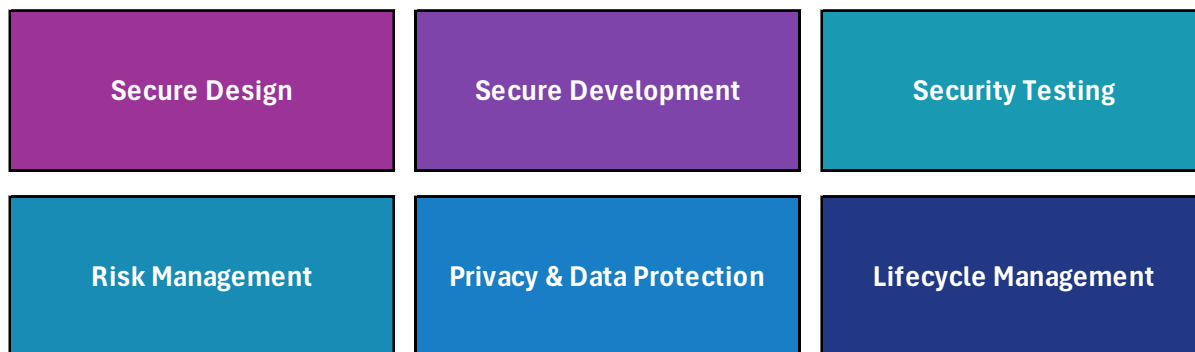


Figure 2: Framework Domains

Secure Design

This domain focuses on incorporating security principles and requirements into the design phase of product development. It involves activities such as threat modeling, architectural risk analysis, and the establishment of secure design requirements. The goal is to proactively address potential security threats and vulnerabilities early in the development process.

Secure Development

This domain emphasizes the implementation of secure coding practices and guidelines during the software development phase. It includes activities such as code reviews, the use of secure coding standards, and the integration of security tools to identify and mitigate vulnerabilities in the codebase. The aim is to ensure that the software is resilient against attacks and adheres to best security practices.

Security Testing

This domain involves the rigorous testing of products to identify and address security weaknesses. It includes various testing methodologies such as static and dynamic analysis and penetration testing. The objective is to validate the effectiveness of security controls and ensure that the product can withstand real-world threats.

Risk Management

This domain focuses on the systematic identification, assessment, and mitigation of security risks throughout the product lifecycle. It involves conducting risk assessments, developing risk mitigation strategies, and continuously monitoring and managing risks. The goal is to minimize the impact of potential safety and security threats to the product, the customer environment, and the patients that the product interacts with.

Privacy & Data Protection

This domain addresses the protection of personal and sensitive data. It involves implementing data protection measures such as encryption, access controls, and data anonymization. The aim is to ensure compliance with privacy regulations and protect user data from unauthorized access and breaches.

Lifecycle Management

This domain focuses on maintaining and enhancing product security throughout its entire lifecycle, from development to decommissioning. It includes processes for managing security updates, patch management, and end-of-life considerations. The objective is to ensure that the product remains secure and compliant with evolving security standards over time.

6. Functions

Functions within the Product Security Capability and Maturity Framework represent the specific activities, processes, and best practices that are essential to achieving comprehensive security across different domains. These functions are critical to the systematic assessment and enhancement of security capabilities throughout the total product lifecycle. Each function plays a unique role in ensuring the security, reliability, and regulatory compliance of medical devices.

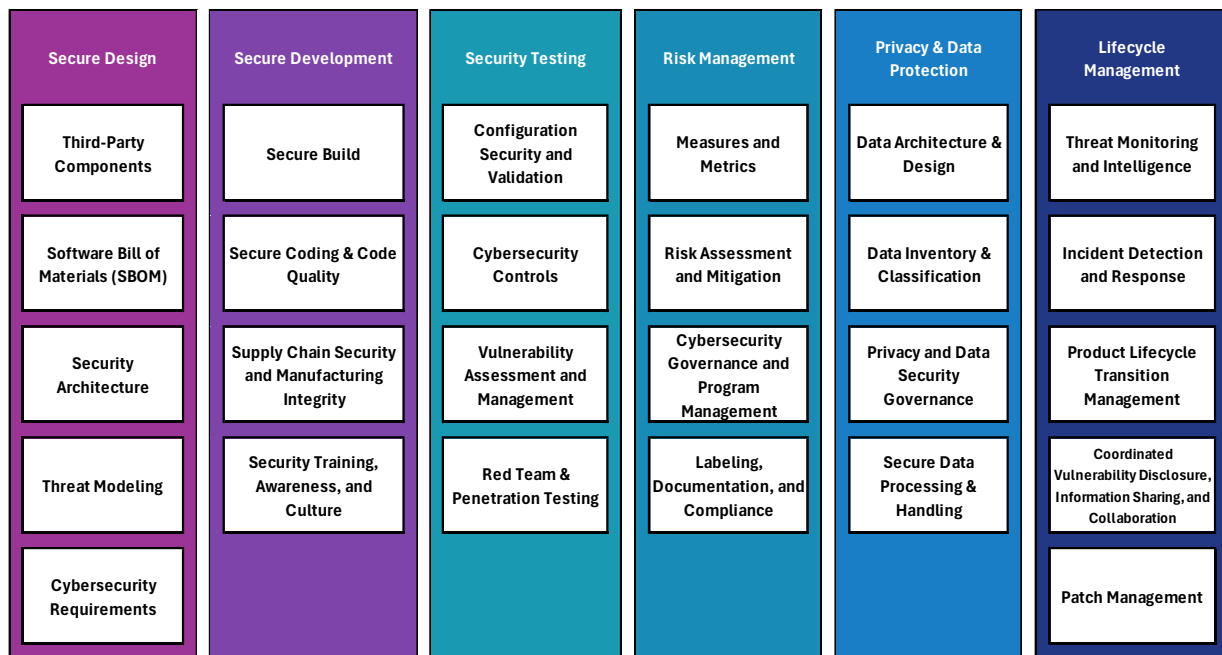
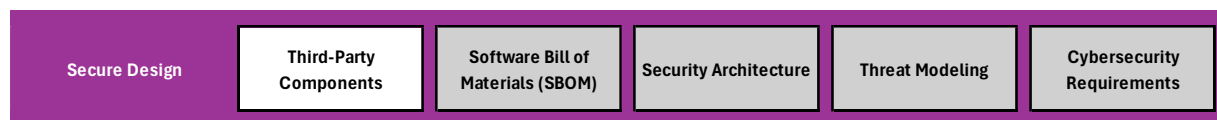


Figure 3: Framework Functions

6.1. Secure Design

Third-Party Components



Third-party components are defined as components over which the organization does not have design or development control, but that are promoted, sold, developed, or integrated within the organization's products, and manufactured by a third-party. The organization retains the same cybersecurity and privacy accountability for third-party products as it does for internally created components.

Scoring Criteria

Ad Hoc (1):

- Documentation is incomplete or inconsistent.
- Security and privacy evaluations are informal and reactive.
- No formal update or replacement plans exist.

Basic (2):

- Basic documentation is available but not comprehensive.
- Initial security and privacy evaluations are conducted, but processes are not standardized.
- Basic update plans are in place, but replacement plans are not fully developed.

Defined (3):

- Comprehensive documentation is reviewed and maintained.
- Formal security and privacy evaluations are conducted and documented.
- Defined processes for updating third-party components are established.
- Replacement plans are developed and documented, identifying alternative solutions.

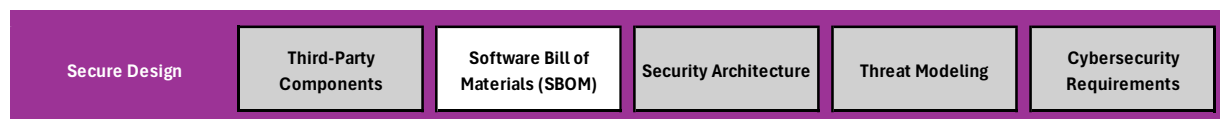
Managed (4):

- Documentation is regularly reviewed and updated.
- Metrics are used to monitor the effectiveness of security and privacy evaluations.
- Quantitative techniques are used to predict and address potential issues with third-party components.
- Update and replacement plans are regularly reviewed and tested.

Optimized (5):

- Documentation and evaluation processes are continuously improved.
- Automation tools are used to enforce security and privacy standards for third-party components.
- Statistical techniques are used to optimize the update and replacement processes.
- Continuous monitoring and feedback loops ensure that third-party components remain secure and compliant.

Software Bill of Materials (SBOM)





A robust Software Bill of Materials (SBOM) includes both organizational-developed components and third-party components, encompassing purchased/licensed software, open-source software, and the upstream software dependencies required or depended upon by proprietary, purchased/licensed, and open-source software.

Scoring Criteria

Ad Hoc (1):

- SBOM practices are inconsistent and informal.
- The SBOM is incomplete and lacks critical information.
- Updates and reviews are conducted on an as-needed basis.

Basic (2):

- A basic SBOM is established, including key components and dependencies.
- The SBOM includes some of the minimum elements identified by the [NTIA](#).
- Support and maintenance information is provided for some components.
- The SBOM is updated periodically, but not consistently.

Defined (3):

- The SBOM is comprehensive and includes all internally developed, purchased/licensed, and open-source software components.
- The SBOM includes all minimum elements identified by the [NTIA](#).
- Support and maintenance information, including end-of-support dates, is provided for each component.
- The SBOM is machine-readable and follows a consistent format.
- Regular updates and formal reviews are conducted to ensure completeness and accuracy.

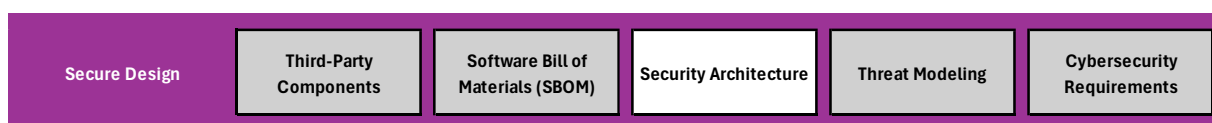
Managed (4):

- Metrics are established to monitor the effectiveness of SBOM practices.
- Quantitative techniques are used to understand and predict performance variations in SBOM management.
- Automation tools are used to generate, update, and maintain the SBOM.
- Regular audits ensure adherence to SBOM standards.

Optimized (5):

- SBOM practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to enforce SBOM standards and detect issues early.
- Statistical techniques are used to optimize SBOM practices and achieve high-quality performance objectives.
- Continuous integration with other tools and systems ensures real-time updates and monitoring of the SBOM.

Security Architecture



The cybersecurity architecture represents the team’s plan for actualizing the cybersecurity objectives determined in the product cybersecurity strategy. It provides for the definition of cybersecurity requirements, and the design and engineering of tools, technologies, processes, and controls that improve and sustain the product’s cybersecurity posture.

Scoring Criteria

Ad Hoc (1):

- Security architecture practices are inconsistent and informal.
- The architecture lacks comprehensive views and documentation.
- Security measures are addressed reactively and on an as-needed basis.

Basic (2):

- Basic security architecture is established, including key views and considerations.
- The architecture addresses fundamental security requirements but lacks detailed documentation.
- Security measures are repeatable but not yet standardized.
- Progress towards security architecture objectives is monitored at a basic level.

Defined (3):

- The security architecture is comprehensive and includes detailed views (Interoperability, Global System, Multi-Patient Harm, Update and Patchability, Security Use Case).
- The architecture is formally defined, documented, and communicated to all relevant stakeholders.
- Organizational standards for security architecture are established and followed.
- Regular reviews and updates ensure the architecture remains current and effective.

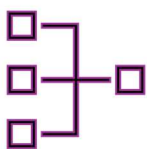
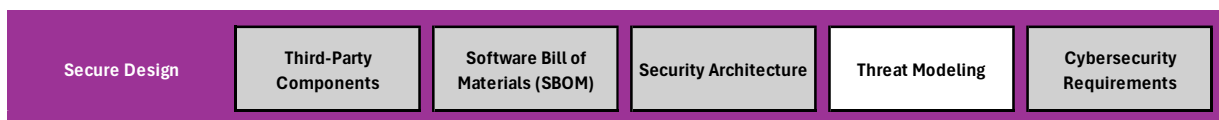
Managed (4):

- Metrics are established to monitor the effectiveness of the security architecture.
- Quantitative techniques are used to understand and predict performance variations in security measures.
- Automation tools are used to enforce security architecture standards and detect issues early.
- Regular audits ensure adherence to security architecture standards.

Optimized (5):

- Security architecture practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize the security architecture and address emerging threats.
- Statistical techniques are used to enhance the architecture's ability to achieve high-quality performance objectives.
- Continuous integration with other tools and systems ensures real-time updates and monitoring of the security architecture.

Threat Modeling



Threat modeling involves capturing cybersecurity risks introduced through various stages of the product lifecycle, including supply chain, manufacturing, deployment, interoperability with other devices, maintenance/update activities, and decommission activities. The threat model provides a detailed analysis of the product, including processes, data stores, data flows, trust boundaries, and interfaces with external entities. The threat model identifies system risks,

mitigations, and assumptions, and establishes traceability of architecture elements to user and system security requirements.

Scoring Criteria

Ad Hoc (1):

- Threat modeling practices are inconsistent and informal.
- The threat model is incomplete and lacks detailed analysis.
- Risks and mitigations are addressed reactively and on an as-needed basis.

Basic (2):

- A basic threat modeling processes are established
- Threat models include key processes, data stores, data flows, and trust boundaries.
- Threat models address fundamental security risks but lack comprehensive documentation.
- Risks and mitigations are identified, but processes are not standardized.
- Progress towards threat modeling objectives is monitored at a basic level.

Defined (3):

- Threat modeling processes are comprehensive and includes detailed analysis of all relevant elements (processes, data stores, data flows, trust boundaries, interfaces).
- The threat model is formally defined, documented, and communicated to all relevant stakeholders.
- Organizational standards for threat modeling are established and followed.
- Risks, mitigations, and assumptions are thoroughly documented.
- Traceability of architecture elements to security requirements is established.

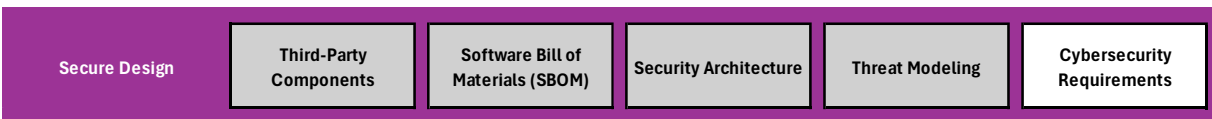
Managed (4):

- Metrics are established to monitor the effectiveness of threat modeling practices.
- Quantitative techniques are used to understand and predict performance variations in threat modeling.
- Regular reviews and audits ensure adherence to threat modeling standards.
- Automation tools are used to support the threat modeling process and maintain traceability.

Optimized (5):

- Threat modeling practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize the threat modeling process and address emerging threats.
- Statistical techniques are used to enhance the threat model's ability to achieve high-quality performance objectives.
- Continuous integration with other tools and systems ensures real-time updates and monitoring of the threat model.

Cybersecurity Requirements



Cybersecurity requirements, like functional requirements, are described through system and software level detailed requirements and expressed to the development team for implementation. Due to the strong resemblance in how cybersecurity and functional requirements are described and implemented, a similar approach should be adopted to ensure their correct implementation through unit testing. This involves providing evidence that each design input requirement was implemented successfully, conducting boundary analysis, and considering legal, regulatory, and customer requirements, as well as industry standards.

Scoring Criteria

Ad Hoc (1):

- Cybersecurity requirement practices are inconsistent and informal.
- Requirements are incomplete and lack detailed documentation.
- Evidence of implementation is sporadic and not systematically collected.
- Compliance with legal, regulatory, and customer requirements is not consistently ensured.

Basic (2):

- Basic cybersecurity requirements are established and documented.
- Requirements are communicated to the development team, but practices are not standardized.
- Evidence of implementation is collected, but not comprehensively.

- Initial efforts to comply with legal, regulatory, and customer requirements are made.

Defined (3):

- Cybersecurity requirements are detailed at both system and software levels and formally documented.
- Requirements are systematically communicated and integrated into the development process.
- Comprehensive evidence of implementation, including unit testing, is provided.
- Legal, regulatory, and customer requirements are documented.
- Requirements align with recognized industry standards and organizational baselines.

Managed (4):

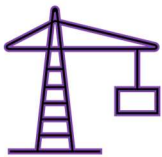
- Metrics are established to monitor the effectiveness of cybersecurity requirement practices.
- Quantitative techniques are used to understand and predict performance variations in requirement implementation.
- Regular reviews and audits ensure adherence to cybersecurity requirement standards.
- Continuous feedback from customers and stakeholders is integrated into the requirements process.

Optimized (5):

- Cybersecurity requirement practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize the definition, communication, and implementation of requirements.
- Statistical techniques are used to enhance the requirement process and achieve high-quality performance objectives.
- Continuous integration with other tools and systems ensures real-time updates and monitoring of cybersecurity requirements.

6.2. Secure Development

Secure Build



Secure build practices involve ensuring that the build processes for software and systems are conducted in a secure manner to prevent the introduction of vulnerabilities. This includes using secure build environments, implementing security checks during the build process, and ensuring the integrity and authenticity of build artifacts.

Scoring Criteria

Ad Hoc (1):

- Secure build practices are inconsistent and informal.
- The build environment is not securely configured or isolated.
- Security checks during the build process are sporadic and not systematically conducted.
- Documentation and traceability are incomplete or lacking.
- Monitoring and improvement efforts are reactive and inconsistent.

Basic (2):

- Basic secure build practices are established and documented.
- Initial efforts to secure the build environment and implement security checks are made.
- The CI/CD pipeline includes basic security checks, but practices are not standardized.
- Documentation is available, but traceability is limited.
- Basic monitoring tools are implemented, and initial efforts for improvement are made.

Defined (3):

- Secure build practices are comprehensively defined, documented, and communicated.
- The build environment is securely configured and isolated.
- Automated security checks are integrated into the build process.
- The CI/CD pipeline is securely configured and includes consistent security checks and automated testing.
- Comprehensive documentation and traceability are maintained.
- Monitoring tools are in place, and regular reviews ensure continuous improvement.

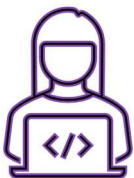
Managed (4):

- Metrics are established to monitor the effectiveness of secure build practices.
- Quantitative techniques are used to understand and predict performance variations in the build process.
- Regular audits ensure adherence to secure build standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Secure build practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize the build process, security checks, and monitoring.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of the build process.

Secure Coding & Code Quality



Secure coding and code quality practices involve ensuring that software development processes follow secure coding standards and maintain high code quality to prevent the introduction of vulnerabilities. This includes implementing secure coding guidelines, conducting code reviews, using automated tools for static and dynamic analysis, and maintaining comprehensive documentation.

Scoring Criteria

Ad Hoc (1):

- Secure coding and code quality practices are inconsistent and informal.
- Secure coding guidelines are not comprehensively developed or communicated.

- Code reviews are sporadic and lack formal criteria.
- Use of automated code analysis tools is limited and not integrated into the development workflow.
- Documentation and traceability are incomplete or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic secure coding and code quality practices are established and documented.
- Secure coding guidelines are communicated to developers, but practices are not standardized.
- Code reviews are conducted periodically, but criteria and documentation are limited.
- Initial efforts to use automated code analysis tools are made, but integration is limited.
- Basic documentation and traceability are available, but not comprehensive.
- Initial efforts for continuous improvement are made.

Defined (3):

- Secure coding and code quality practices are comprehensively defined, documented, and communicated.
- Secure coding guidelines are systematically followed, and developers receive regular training.
- Formal code review processes with defined criteria are implemented and consistently followed.
- Automated static and dynamic analysis tools are integrated into the development workflow.
- Comprehensive documentation and traceability are maintained.
- Regular feedback loops and reviews ensure continuous improvement.

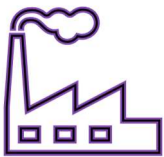
Managed (4):

- Metrics are established to monitor the effectiveness of secure coding and code quality practices.
- Quantitative techniques are used to understand and predict performance variations in code quality.
- Regular audits ensure adherence to secure coding and code quality standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Secure coding and code quality practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize code analysis, code reviews, and monitoring.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of code quality.

Supply Chain Security and Manufacturing Integrity



Supply chain security and manufacturing integrity involve ensuring that all components, processes, and partners involved in the supply chain and manufacturing process adhere to stringent security standards. This includes assessing and managing risks associated with third-party suppliers, verifying the integrity of components, and implementing robust security measures throughout the manufacturing process.

Scoring Criteria

Ad Hoc (1):

- Supply chain security and manufacturing integrity practices are inconsistent and informal.
- Supplier evaluations are not comprehensively conducted or documented.
- Component verification processes are limited and not systematically implemented.
- Secure manufacturing practices are sporadic and lack formal documentation.
- Monitoring, validation, and incident response efforts are reactive and inconsistent.
- Documentation and communication are incomplete or lacking.

Basic (2):

- Basic supply chain security and manufacturing integrity practices are established and documented.
- Initial efforts to evaluate and manage suppliers are made.
- Component verification processes are implemented but not fully standardized.
- Secure manufacturing practices are documented and communicated.

- Basic monitoring tools and validation processes are in place.
- Initial incident response and remediation processes are established.
- Basic documentation and communication practices are available.

Defined (3):

- Supply chain security and manufacturing integrity practices are comprehensively defined, documented, and communicated.
- Thorough supplier evaluation and management processes are established.
- Component verification processes are systematically implemented and regularly reviewed.
- Secure manufacturing practices are consistently followed and regularly audited.
- Continuous monitoring tools and regular validation processes are in place.
- Comprehensive incident response and remediation plans are maintained.
- Comprehensive documentation and communication practices are maintained.

Managed (4):

- Metrics are established to monitor the effectiveness of supply chain security and manufacturing integrity practices.
- Quantitative techniques are used to understand and predict performance variations in supply chain security.
- Regular audits ensure adherence to supply chain and manufacturing security standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Supply chain security and manufacturing integrity practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize supplier evaluation, component verification, and manufacturing security processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of supply chain and manufacturing security.

Security Training, Awareness, and Culture



Security training, awareness, and culture involve educating and engaging employees at all levels of the engineering organization to ensure they understand and adhere to security best practices. This includes providing regular training sessions, promoting awareness of security threats and policies, and fostering a security-conscious culture throughout the organization.

Scoring Criteria

Ad Hoc (1):

- Security training, awareness, and culture practices are inconsistent and informal.
- Training programs are limited and not regularly updated.
- Awareness initiatives are sporadic and lack engagement activities.
- Leadership support for security culture is minimal.
- Monitoring and assessment of training effectiveness and awareness levels are not systematically conducted.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic security training programs are established and documented.
- Initial efforts to promote security awareness and engage employees are made.
- Leadership communicates the importance of security, but practices are not standardized.
- Basic monitoring and assessment of training effectiveness are conducted.
- Initial efforts for continuous improvement are made.

Defined (3):

- Comprehensive security training programs are defined, documented, and communicated.
- Ongoing security awareness initiatives and engagement activities are implemented.
- Leadership actively supports and promotes a security-conscious culture.
- Regular monitoring and assessment of training effectiveness and awareness levels are conducted.
- Feedback loops and benchmarking are used to continuously improve programs.

Managed (4):

- Metrics are established to monitor the effectiveness of security training, awareness, and culture practices.
- Quantitative techniques are used to understand and predict performance variations in training and awareness.
- Regular audits ensure adherence to security training and awareness standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Security training, awareness, and culture practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize training delivery, monitoring, and engagement activities.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of training and awareness levels.

6.3. Security Testing

Configuration Security and Validation



Configuration security and validation involve ensuring that components are configured securely to prevent unintentional vulnerabilities that can be easily exploited. This includes addressing issues such as exposing interfaces to untrusted networks, retaining unused or development functionality, and using improper authentication/authorization of accessible resources.

Scoring Criteria

Ad Hoc (1):

- Configuration security practices are inconsistent and informal.
- Configuration requirements are not comprehensively identified or documented.
- Validation processes are sporadic and not systematically conducted.
- Monitoring and remediation efforts are reactive and inconsistent.

Basic (2):

- Basic configuration security practices are established and documented.
- Initial efforts to identify and document configuration requirements are made.
- Validation processes are conducted periodically but lack consistency.

Defined (3):

- Configuration security requirements are comprehensively identified, documented, and communicated.
- Secure configuration settings are consistently implemented across all components.
- Regular validation processes, including automated and manual checks, are conducted to ensure secure configurations.

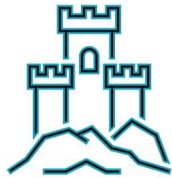
Managed (4):

- Metrics are established to monitor the effectiveness of configuration security practices.
- Quantitative techniques are used to understand and predict performance variations in configuration security.
- Regular audits ensure adherence to configuration security standards.
- Validation processes are integrated into the overall security management framework.

Optimized (5):

- Configuration security practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize configuration implementation, monitoring, and validation.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates of configuration security.

Cybersecurity Controls



Cybersecurity controls are measures implemented to protect systems, networks, and data from security threats and vulnerabilities. These controls can be preventive, detective, and corrective, and they include policies, procedures, technologies, and practices designed to mitigate risks and ensure the integrity, confidentiality, and availability of information.

Scoring Criteria

Ad Hoc (1):

- Cybersecurity control practices are inconsistent and informal.
- Controls are not comprehensively identified, documented, or implemented.
- Testing, validation, and monitoring of controls are sporadic and not systematically conducted.
- Incident response and remediation efforts are reactive and inconsistent.
- Compliance and audit processes are limited or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic cybersecurity control practices are established and documented.
- Initial efforts to implement and configure controls are made.
- Basic testing and validation of controls are conducted, but practices are not standardized.
- Initial incident detection and response mechanisms are in place.
- Basic compliance and audit processes are established.
- Initial efforts for continuous improvement are made.

Defined (3):

- Cybersecurity control practices are comprehensively defined, documented, and communicated.
- Controls are systematically implemented and configured to meet security requirements.
- Regular testing, validation, and monitoring of controls are conducted to ensure effectiveness.
- Comprehensive incident response and remediation plans are maintained.

- Compliance with regulatory and industry standards is ensured and documented.
- Regular audits are conducted to assess control effectiveness and compliance.
- Feedback loops and benchmarking are used to continuously improve controls.

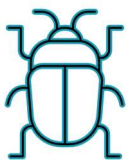
Managed (4):

- Metrics are established to monitor the effectiveness of cybersecurity control practices.
- Quantitative techniques are used to understand and predict performance variations in controls.
- Regular audits ensure adherence to cybersecurity control standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Cybersecurity control practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize control implementation, monitoring, and incident response.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of controls.

Vulnerability Assessment and Management



Vulnerability assessment and management involve identifying, evaluating, and mitigating security vulnerabilities within product design. This process includes regular vulnerability scans, risk assessment, prioritization of remediation efforts, and continuous monitoring to ensure vulnerabilities are addressed promptly and effectively.

Scoring Criteria

Ad Hoc (1):

- Vulnerability assessment and management practices are inconsistent and informal.
- Vulnerability scanning and testing are sporadic and not systematically conducted.
- Risk assessment and prioritization are limited or lacking.
- Remediation and mitigation efforts are reactive and inconsistent.
- Documentation and reporting are incomplete or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic vulnerability assessment and management practices are established and documented.
- Initial efforts to conduct regular vulnerability scans and manual testing are made.
- Basic risk assessment and prioritization processes are implemented.
- Initial remediation and mitigation plans are developed and tracked.
- Basic documentation and reporting practices are available.
- Initial efforts for continuous improvement are made.

Defined (3):

- Vulnerability assessment and management practices are comprehensively defined, documented, and communicated.
- Regular vulnerability scans and manual testing are systematically conducted.
- Formal risk assessment and prioritization processes are established and followed.
- Comprehensive remediation and mitigation plans are developed and tracked.
- Comprehensive documentation and reporting practices are maintained.
- Feedback loops and benchmarking are used to continuously improve practices.

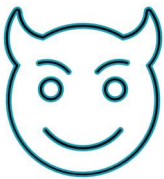
Managed (4):

- Metrics are established to monitor the effectiveness of vulnerability assessment and management practices.
- Quantitative techniques are used to understand and predict performance variations in vulnerability management.
- Regular audits ensure adherence to vulnerability management standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Vulnerability assessment and management practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize vulnerability scanning, risk assessment, and remediation processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of vulnerabilities.

Red Team & Penetration Testing



Red team and penetration testing involve conducting simulated attacks on a product to identify security weaknesses that could be exploited to cause the device to function outside its intended use or to cause patient harm.

Scoring Criteria

Ad Hoc (1):

- Penetration testing practices are inconsistent and informal.
- Testing scope and objectives are not clearly defined.
- Testing methodologies are limited or lacking.
- Risk assessment and mitigation efforts are reactive and inconsistent.
- Documentation and reporting are incomplete or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic penetration testing practices are established and documented.
- Initial efforts to define testing scope and objectives are made.
- Basic testing at different levels is conducted, but practices are not standardized.
- Initial testing methodologies are developed and followed.
- Basic risk assessment and mitigation plans are implemented.
- Basic documentation and reporting practices are available.
- Initial efforts for continuous improvement are made.

Defined (3):

- Penetration testing practices are comprehensively defined, documented, and communicated.
- Testing scope and objectives are clearly defined and aligned with security and safety requirements.
- Systematic testing at different levels is conducted.
- Detailed testing methodologies are developed and consistently followed.
- Comprehensive risk assessment and mitigation plans are implemented and tracked.
- Comprehensive documentation and reporting practices are maintained.
- Feedback loops and benchmarking are used to continuously improve practices.

Managed (4):

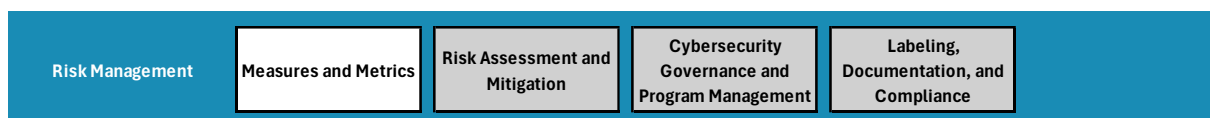
- Metrics are established to monitor the effectiveness of penetration testing practices.
- Quantitative techniques are used to understand and predict performance variations in testing.
- Regular audits ensure adherence to penetration testing standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Penetration testing practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize testing methodologies, risk assessment, and mitigation processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of vulnerabilities.

6.4. Risk Management

Measures and Metrics





Measures and Metrics involve the systematic collection, analysis, and reporting of data to evaluate and improve the effectiveness of security programs and processes within an engineering organization. This includes defining key performance indicators (KPIs), establishing benchmarks, tracking progress, and using data-driven insights to inform decision-making and drive continuous improvement.

Scoring Criteria

Ad Hoc (1):

- Measures and metrics practices are inconsistent and informal.
- Data collection is sporadic and not systematically conducted.
- KPIs are limited or lacking, and there is no formal process for defining them.
- Analysis and reporting of metrics are incomplete or lacking.
- Decision-making is not consistently informed by data.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic measures and metrics practices are established and documented.
- Initial efforts to collect data regularly are made.
- Basic KPIs are defined and tracked.
- Initial analysis and reporting practices are implemented.
- Some decision-making is informed by data.
- Initial efforts for continuous improvement are made using available metrics.

Defined (3):

- Measures and metrics practices are comprehensively defined, documented, and communicated.
- Regular data collection is systematically conducted.
- Formal processes for defining and tracking KPIs are established and followed. Comprehensive analysis and reporting practices are maintained.
- Decision-making is consistently informed by data-driven insights.
- Feedback loops and benchmarking are used to continuously improve measures and metrics practices.

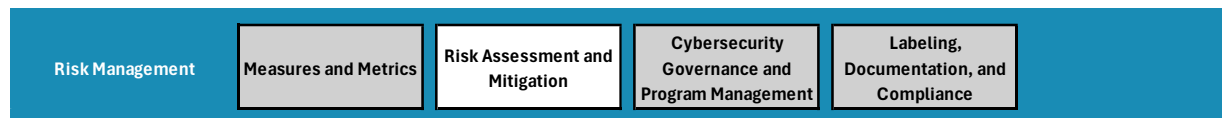
Managed (4):

- Metrics are established to monitor the effectiveness of measures and metrics practices.
- Quantitative techniques are used to understand and predict performance variations.
- Regular audits ensure adherence to metrics and measurement standards.
- Continuous monitoring and validation processes are integrated into the overall management framework.
- Data is used to proactively identify areas for improvement and drive strategic initiatives.

Optimized (5):

- Measures and metrics practices are continuously improved through regular monitoring and feedback loops.
- Advanced analytics and automation tools are used to optimize data collection, analysis, and reporting processes.
- Statistical techniques and predictive analytics are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other management tools ensures real-time updates and comprehensive visibility into organizational performance.
- Metrics are aligned with strategic goals and used to drive innovation and transformation efforts across the organization.

Risk Assessment and Mitigation



Risk assessment and mitigation involve identifying, evaluating, and addressing cybersecurity risks within an engineering organization and the products they develop. This includes conducting thorough risk assessments to determine the potential impact and likelihood of risks, prioritizing risks based on their severity, and implementing mitigation strategies to reduce or eliminate risks.

Scoring Criteria

Ad Hoc (1):

- Risk assessment and mitigation practices are inconsistent and informal.
- Asset, threat, and vulnerability identification are not comprehensively conducted or documented.

- Risk assessment and scoring processes are limited or lacking.
- Mitigation strategies and action plans are reactive and inconsistent.
- Validation and monitoring efforts are sporadic and not systematically conducted.
- Documentation and reporting are incomplete or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic risk assessment and mitigation practices are established and documented.
- Initial efforts to identify assets, threats, and vulnerabilities are made.
- Basic risk assessment and scoring processes are implemented.
- Initial mitigation strategies and action plans are developed and tracked.
- Basic validation and monitoring processes are in place.
- Basic documentation and reporting practices are available.
- Initial efforts for continuous improvement are made.

Defined (3):

- Risk assessment and mitigation practices are comprehensively defined, documented, and communicated.
- Systematic identification of threats and vulnerabilities is conducted.
- Formal risk assessment and scoring processes are established and consistently applied.
- Comprehensive mitigation strategies and action plans are developed and tracked.
- Regular validation and continuous monitoring processes are conducted to ensure effectiveness.
- Comprehensive documentation and reporting practices are maintained.
- Feedback loops and benchmarking are used to continuously improve practices.

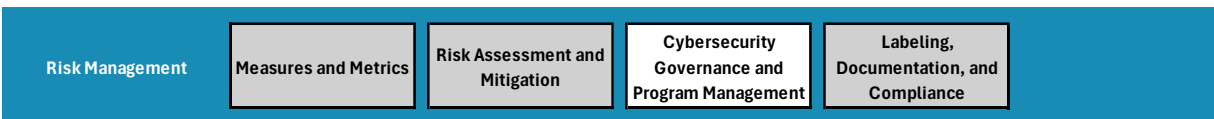
Managed (4):

- Metrics are established to monitor the effectiveness of risk assessment and mitigation practices.
- Quantitative techniques are used to understand and predict performance variations in risk management.
- Regular audits ensure adherence to risk assessment and mitigation standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Risk assessment and mitigation practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize risk identification, assessment, and mitigation processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of risks.

Cybersecurity Governance and Program Management



Cybersecurity governance and program management involve establishing a structured framework to oversee and manage the engineering organization's cybersecurity efforts. This includes defining roles and responsibilities, creating policies and procedures, ensuring compliance with regulatory requirements, and continuously improving the cybersecurity posture through strategic planning and resource allocation.

Scoring Criteria

Ad Hoc (1):

- Cybersecurity governance and program management practices are inconsistent and informal.
- Roles and responsibilities are not clearly defined or documented.
- Policies and procedures are limited or lacking.
- Compliance efforts are sporadic and not systematically conducted.
- Strategic planning and resource allocation are reactive and inconsistent.
- Program management oversight and project management practices are limited or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic cybersecurity governance and program management practices are established and documented.
- Initial efforts to define roles and responsibilities are made.

- Basic policies and procedures are developed and communicated.
- Initial compliance efforts and audits are conducted.
- Basic strategic planning and resource allocation processes are implemented.
- Initial program management oversight and project management practices are in place.
- Initial efforts for continuous improvement are made.

Defined (3):

- Cybersecurity governance and program management practices are comprehensively defined, documented, and communicated.
- Clear roles and responsibilities are established and documented.
- Comprehensive policies and procedures are developed, regularly updated, and aligned with regulatory requirements.
- Regular compliance audits are conducted, and findings are addressed.
- A documented cybersecurity strategy and resource allocation plan are in place.
- A program management function oversees the implementation of initiatives, and project management practices are consistently followed.
- Feedback loops and benchmarking are used to continuously improve practices.

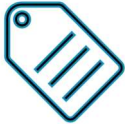
Managed (4):

- Metrics are established to monitor the effectiveness of cybersecurity governance and program management practices.
- Quantitative techniques are used to understand and predict performance variations in governance and program management.
- Regular audits ensure adherence to governance and program management standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Cybersecurity governance and program management practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize policy development, compliance monitoring, and project management processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of governance and program management activities.

Labeling, Documentation, and Compliance



Labeling, documentation, and compliance involve the creation, maintenance, and management of comprehensive documentation related to cybersecurity activities and measures. This includes ensuring that all relevant documentation is accurate, accessible, and compliant with regulatory and industry standards. Proper labeling and documentation help in demonstrating compliance, facilitating audits, and ensuring transparency in cybersecurity practices.

Scoring Criteria

Ad Hoc (1):

- Labeling, documentation, and compliance practices are inconsistent and informal.
- Documentation is incomplete and lacks comprehensive coverage of cybersecurity activities.
- Compliance efforts are sporadic and not systematically conducted.
- Accessibility and security of documentation are limited or lacking.
- Training and awareness programs are minimal or nonexistent.
- Reporting and auditing practices are limited or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic labeling, documentation, and compliance practices are established and documented.
- Initial efforts to create and maintain comprehensive documentation are made.
- Basic compliance audits are conducted, but practices are not standardized.
- Initial measures for document accessibility and security are implemented.
- Basic training programs on documentation and compliance are developed.
- Initial reporting and internal audit practices are established.
- Initial efforts for continuous improvement are made.

Defined (3):

- Labeling, documentation, and compliance practices are comprehensively defined, documented, and communicated.

- Comprehensive documentation covering all cybersecurity activities is maintained.
- Regular compliance audits are conducted, and findings are addressed.
- Secure document management systems ensure accessibility and data protection.
- Training programs on documentation and compliance are regularly updated and delivered.
- Regular reporting and internal audit practices are in place.
- Feedback loops and benchmarking are used to continuously improve practices.

Managed (4):

- Metrics are established to monitor the effectiveness of labeling, documentation, and compliance practices.
- Quantitative techniques are used to understand and predict performance variations in documentation and compliance.
- Regular audits ensure adherence to documentation and compliance standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

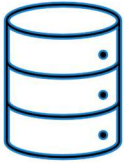
Optimized (5):

- Labeling, documentation, and compliance practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize documentation management, compliance monitoring, and reporting processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of documentation and compliance activities.

6.5. Privacy & Data Protection

Data Architecture & Design





Data architecture and design involve the structured organization, storage, and management of data within an engineering organization, and within a product design to ensure its privacy and protection. This includes defining data models, establishing data governance, implementing data protection measures, and ensuring compliance with regulatory requirements.

Scoring Criteria

Ad Hoc (1):

- Data architecture and design practices are inconsistent and informal.
- Data modeling and classification are not comprehensively conducted or documented.
- Data protection measures are sporadic and not systematically implemented.
- Compliance efforts are sporadic and not systematically conducted.
- Documentation and reporting are incomplete or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic product data architecture and design practices are established and documented.
- Initial efforts to create and maintain product data models and classification are made.
- Initial data protection measures are implemented in the product design.
- Basic monitoring and auditing processes are in place.
- Basic documentation and reporting practices are available.
- Initial efforts for continuous improvement are made.

Defined (3):

- Product Data architecture and design practices are comprehensively defined, documented, and communicated.
- Comprehensive product data models and data classification are maintained.
- Comprehensive data protection measures are systematically implemented.
- Comprehensive documentation and reporting practices are maintained.
- Feedback loops and benchmarking are used to continuously improve practices.

Managed (4):

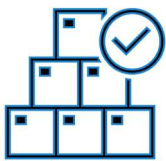
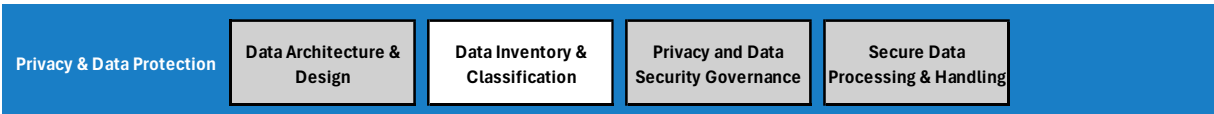
- Metrics are established to monitor the effectiveness of product data architecture and design practices.

- Quantitative techniques are used to understand and predict performance variations in data protection.
- Regular audits ensure adherence to data architecture and design standards.
- Continuous monitoring and validation processes are integrated into the overall data protection framework.

Optimized (5):

- Data architecture and design practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize data modeling, governance, protection, and compliance processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other data protection tools ensures real-time updates and monitoring of data architecture and design activities.
-

Data Inventory & Classification



Data inventory and classification activities involve identifying, cataloging, and categorizing of all data assets within an engineering organization and within a product design. This process helps in understanding the types, locations, and sensitivity of data, enabling the implementation of appropriate data protection measures and compliance with regulatory requirements.

Scoring Criteria

Ad Hoc (1):

- Data inventory and classification practices are inconsistent and informal.
- Data inventory is incomplete and lacks comprehensive coverage of data assets.
- Data classification criteria and processes are limited or lacking.
- Data tagging and labeling mechanisms are not systematically implemented.
- Access control and data protection measures are sporadic and not consistently enforced.

- Compliance efforts are sporadic and not systematically conducted.
- Monitoring and auditing efforts are sporadic and not systematically conducted.
- Documentation and reporting are incomplete or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic data inventory and classification practices are established and documented.
- Initial efforts to create and maintain a data inventory are made.
- Basic data classification criteria and processes are developed and communicated.
- Initial data tagging and labeling mechanisms are implemented.
- Basic access control and data protection measures are enforced.
- Initial compliance efforts and audits are conducted.
- Basic monitoring and auditing processes are in place.
- Basic documentation and reporting practices are available.
- Initial efforts for continuous improvement are made.

Defined (3):

- Data inventory and classification practices are comprehensively defined, documented, and communicated.
- Comprehensive data inventory covering all data assets is maintained.
- Formal data classification criteria and processes are established and consistently applied.
- Systematic data tagging and labeling mechanisms are implemented and integrated with data management systems.
- Comprehensive access control and data protection measures are enforced based on classification levels.
- Regular compliance audits are conducted, and findings are addressed.
- Regular monitoring and auditing processes are conducted to ensure effectiveness.
- Comprehensive documentation and reporting practices are maintained.
- Feedback loops and benchmarking are used to continuously improve practices.

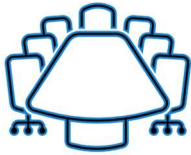
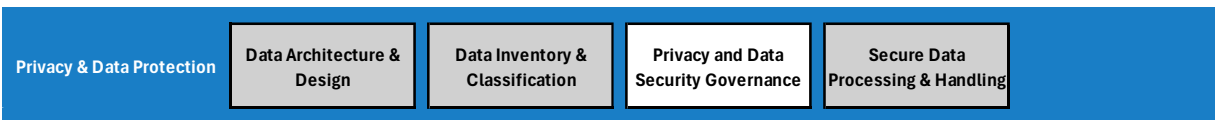
Managed (4):

- Metrics are established to monitor the effectiveness of data inventory and classification practices.
- Quantitative techniques are used to understand and predict performance variations in data protection.
- Regular audits ensure adherence to data inventory and classification standards.
- Continuous monitoring and validation processes are integrated into the overall data protection framework.

Optimized (5):

- Data inventory and classification practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize data discovery, classification, tagging, and protection processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other data protection tools ensures real-time updates and monitoring of data inventory and classification activities.

Privacy and Data Security Governance



Privacy and data security governance involve establishing a structured framework to oversee and manage the engineering organization's privacy and data protection efforts as well as those designed into our products. This includes defining roles and responsibilities, creating policies and procedures, ensuring compliance with regulatory requirements, and continuously improving the privacy and data security posture through strategic planning and resource allocation.

Scoring Criteria

Ad Hoc (1):

- Privacy and data security governance practices are inconsistent and informal.
- Roles and responsibilities are not clearly defined or documented.
- Policies and procedures are limited or lacking.
- Compliance efforts are sporadic and not systematically conducted.
- Strategic planning and resource allocation are reactive and inconsistent.
- Program management oversight and project management practices are limited or lacking.
- Training and awareness programs are minimal or nonexistent.
- Monitoring and auditing efforts are sporadic and not systematically conducted.
- Documentation and reporting are incomplete or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic privacy and data security governance practices are established and documented.
- Initial efforts to define roles and responsibilities are made.
- Basic policies and procedures are developed and communicated.
- Initial compliance audits are conducted, but practices are not standardized.
- Basic strategic planning and resource allocation processes are implemented.
- Initial program management oversight and project management practices are in place.
- Basic training programs on privacy and data security are developed.
- Initial monitoring and auditing processes are in place.
- Basic documentation and reporting practices are available.
- Initial efforts for continuous improvement are made.

Defined (3):

- Privacy and data security governance practices are comprehensively defined, documented, and communicated.
- Clear roles and responsibilities are established and documented.
- Comprehensive policies and procedures are developed, regularly updated, and aligned with regulatory requirements.
- Regular compliance audits are conducted, and findings are addressed.
- A documented privacy and data security strategy and resource allocation plan are in place.
- A privacy and data security program management office oversees the implementation of initiatives, and project management practices are consistently followed.
- Regular training and awareness programs on privacy and data security are delivered.
- Regular monitoring and auditing processes are conducted to ensure effectiveness.
- Comprehensive documentation and reporting practices are maintained.
- Feedback loops and benchmarking are used to continuously improve practices.

Managed (4):

- Metrics are established to monitor the effectiveness of privacy and data security governance practices.
- Quantitative techniques are used to understand and predict performance variations in governance and program management.
- Regular audits ensure adherence to privacy and data security governance standards.
- Continuous monitoring and validation processes are integrated into the overall data protection framework.

Optimized (5):

- Privacy and data security governance practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize policy development, compliance monitoring, and project management processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other data protection tools ensures real-time updates and monitoring of privacy and data security governance activities.

Secure Data Processing & Handling



Secure data processing and handling involve implementing and maintaining practices that ensure data integrity, confidentiality, and availability throughout the data lifecycle. This includes data collection, storage, processing, transmission, and deletion, as well as implementing appropriate security measures to protect data from unauthorized access, alteration, and loss. This applies to the engineering organization as well as the product design processes.

Scoring Criteria

Ad Hoc (1):

- Data processing and handling practices are inconsistent and informal.
- Data collection, storage, processing, transmission, and deletion practices are not comprehensively conducted or documented.
- Access controls and data protection measures are sporadic and not systematically implemented.
- Compliance efforts are sporadic and not systematically conducted.
- Monitoring and auditing efforts are sporadic and not systematically conducted.
- Documentation and reporting are incomplete or lacking.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic data processing and handling practices are established and documented.

- Initial efforts to implement secure data collection, storage, processing, transmission, and deletion practices are made.
- Basic access control and data protection measures are enforced.
- Initial compliance audits are conducted, but practices are not standardized.
- Basic monitoring and auditing processes are in place.
- Basic documentation and reporting practices are available.
- Initial efforts for continuous improvement are made.

Defined (3):

- Data processing and handling practices are comprehensively defined, documented, and communicated.
- Comprehensive data collection, storage, processing, transmission, and deletion practices are maintained.
- Formal access control and data protection measures are established and consistently applied.
- Regular compliance audits are conducted, and findings are addressed.
- Regular monitoring and auditing processes are conducted to ensure effectiveness.
- Comprehensive documentation and reporting practices are maintained.
- Feedback loops and benchmarking are used to continuously improve practices.

Managed (4):

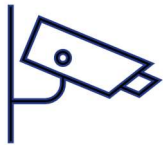
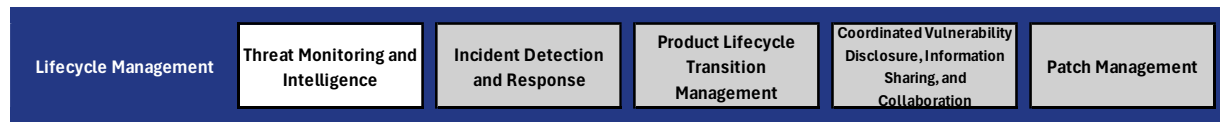
- Metrics are established to monitor the effectiveness of data processing and handling practices.
- Quantitative techniques are used to understand and predict performance variations in data protection.
- Regular audits ensure adherence to data processing and handling standards.
- Continuous monitoring and validation processes are integrated into the overall data protection framework.

Optimized (5):

- Data processing and handling practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize data collection, storage, processing, transmission, and deletion processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other data protection tools ensures real-time updates and monitoring of data processing and handling activities.

6.6. Lifecycle Management

Threat Monitoring and Intelligence



Threat monitoring and intelligence involves the continuous collection, analysis, and dissemination of information related to potential cybersecurity threats. This process helps engineering organizations detect, respond to, and mitigate threats in a timely manner, ensuring the ongoing protection of systems, data, and networks throughout their lifecycle.

Scoring Criteria

Ad Hoc (1):

- Threat monitoring and intelligence practices are inconsistent and informal.
- Sources of threat intelligence are limited or not comprehensively documented.
- Analytical techniques and correlation processes are sporadic and not systematically conducted.
- Continuous monitoring and alerting are limited or lacking.
- Incident response and mitigation efforts are reactive and inconsistent.
- Threat intelligence sharing is minimal or nonexistent.
- Documentation and reporting are incomplete or lacking.
- Compliance and auditing efforts are sporadic and not systematically conducted.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic threat monitoring and intelligence practices are established and documented.
- Initial efforts to identify and document sources of threat intelligence are made.
- Basic analytical techniques and correlation processes are implemented.
- Initial continuous monitoring and alerting processes are in place.
- Basic incident response and mitigation plans are developed.
- Initial efforts to share threat intelligence internally and externally are made.
- Basic documentation and reporting practices are available.
- Initial compliance audits are conducted, but practices are not standardized.

- Initial efforts for continuous improvement are made.

Defined (3):

- Threat monitoring and intelligence practices are comprehensively defined, documented, and communicated.
- Reliable sources of threat intelligence are identified, documented, and regularly reviewed.
- Advanced analytical techniques and systematic correlation processes are established and consistently applied.
- Comprehensive continuous monitoring and alerting processes are in place.
- A formal incident response plan and mitigation strategies are established and followed.
- Regular threat intelligence sharing with internal and external stakeholders is conducted.
- Comprehensive documentation and reporting practices are maintained.
- Regular compliance audits are conducted, and findings are addressed.
- Feedback loops and benchmarking are used to continuously improve practices.

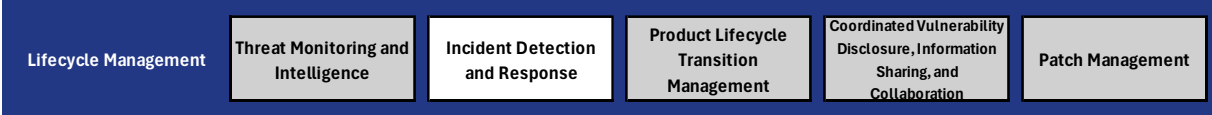
Managed (4):

- Metrics are established to monitor the effectiveness of threat monitoring and intelligence practices.
- Quantitative techniques are used to understand and predict performance variations in threat detection and response.
- Regular audits ensure adherence to threat monitoring and intelligence standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Threat monitoring and intelligence practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize threat intelligence collection, analysis, detection, and response processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of threat intelligence activities.

Incident Detection and Response



Incident detection and response involves identifying, analyzing, and mitigating cybersecurity incidents to minimize their impact on the engineering organization and products. This includes implementing tools and processes for detection of security events, establishing incident response plans, and ensuring effective communication and remediation efforts.

Scoring Criteria

Ad Hoc (1):

- Incident detection and response practices are inconsistent and informal.
- Monitoring and alerting are limited or lacking.
- Incident analysis and root cause investigation processes are sporadic and not systematically conducted.
- Incident response plans are incomplete or not regularly updated.
- Containment, eradication, and recovery efforts are reactive and inconsistent.
- Communication and coordination efforts are limited or lacking.
- Documentation and reporting are incomplete or lacking.
- Compliance and auditing efforts are sporadic and not systematically conducted.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic incident detection and response practices are established and documented.
- Initial efforts to implement monitoring and alerting are made.
- Basic incident analysis and root cause investigation processes are developed.
- Initial incident response plans are created but not regularly updated.
- Basic containment, eradication, and recovery strategies are implemented.
- Initial communication and coordination processes are established.
- Basic documentation and reporting practices are available.
- Initial compliance audits are conducted, but practices are not standardized.
- Initial efforts for continuous improvement are made.

Defined (3):

- Incident detection and response practices are comprehensively defined, documented, and communicated.
- Comprehensive monitoring and alerting processes are in place.
- Formal incident analysis and root cause investigation processes are established and consistently applied.
- A comprehensive incident response plan is developed, maintained, and regularly updated.
- Systematic containment, eradication, and recovery strategies are implemented and followed.
- Regular communication and coordination processes are in place for both internal and external stakeholders.
- Comprehensive documentation and reporting practices are maintained.
- Regular compliance audits are conducted, and findings are addressed.
- Feedback loops and benchmarking are used to continuously improve practices.

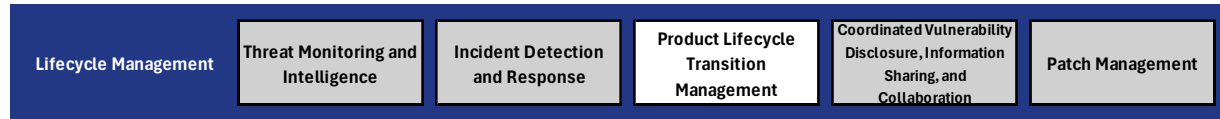
Managed (4):

- Metrics are established to monitor the effectiveness of incident detection and response practices.
- Quantitative techniques are used to understand and predict performance variations in incident response.
- Regular audits ensure adherence to incident detection and response standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Incident detection and response practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize detection, analysis, response, and recovery processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of incident response activities.

Product Lifecycle Transition Management



Product lifecycle transition management involves overseeing the secure and efficient transition of products through their various lifecycle stages, including development, deployment, maintenance, end-of-service (EOS), and end-of-life (EOL). This ensures that security and privacy are maintained throughout the product's lifecycle and that risks associated with transitions are effectively managed.

Scoring Criteria

Ad Hoc (1):

- Product lifecycle transition management practices are inconsistent and informal.
- Lifecycle stages and transition plans are not comprehensively documented.
- Secure development, deployment, and maintenance practices are sporadic and not systematically implemented.
- EOS and EOL transition processes are limited or lacking.
- Risk management efforts are reactive and inconsistent.
- Stakeholder communication is limited or lacking.
- Documentation and reporting are incomplete or lacking.
- Compliance and auditing efforts are sporadic and not systematically conducted.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic product lifecycle transition management practices are established and documented.
- Initial efforts to define lifecycle stages and develop transition plans are made.
- Basic secure development, deployment, and maintenance practices are implemented.
- Initial EOS and EOL transition processes are developed.
- Basic risk assessment and mitigation strategies are in place.
- Initial communication processes for internal and customer stakeholders are established.
- Basic documentation and reporting practices are available.
- Initial compliance audits are conducted, but practices are not standardized.
- Initial efforts for continuous improvement are made.

Defined (3):

- Product lifecycle transition management practices are comprehensively defined, documented, and communicated.
- Clear lifecycle stages and detailed transition plans are established and consistently applied.
- Comprehensive secure development, deployment, and maintenance practices are maintained.
- Formal EOS and EOL transition processes are developed and communicated to customers.
- Systematic risk assessment and mitigation strategies are implemented and tracked.
- Regular communication processes for internal and customer stakeholders are in place.
- Comprehensive documentation and reporting practices are maintained.
- Regular compliance audits are conducted, and findings are addressed.
- Feedback loops and benchmarking are used to continuously improve practices.

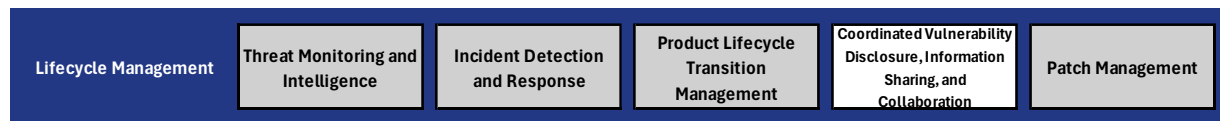
Managed (4):

- Metrics are established to monitor the effectiveness of product lifecycle transition management practices.
- Quantitative techniques are used to understand and predict performance variations in lifecycle transitions.
- Regular audits ensure adherence to lifecycle transition management standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Product lifecycle transition management practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize transition planning, risk management, and communication processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of lifecycle transition activities.

Coordinated Vulnerability Disclosure, Information Sharing, and Collaboration



Coordinated vulnerability disclosure, information sharing, and collaboration involve the structured process of identifying, reporting, and addressing security vulnerabilities in a cooperative manner with stakeholders, including security researchers, industry partners, and regulatory bodies. This ensures that vulnerabilities are disclosed responsibly, mitigated effectively, and that information is shared to enhance overall cybersecurity.

Scoring Criteria

Ad Hoc (1):

- Vulnerability disclosure, information sharing, and collaboration practices are inconsistent and informal.
- Vulnerability disclosure policies are limited or lacking.
- Reporting mechanisms and triage processes are sporadic and not systematically implemented.
- Analysis, mitigation, and remediation efforts are reactive and inconsistent.
- Communication and coordination efforts are limited or lacking.
- Information-sharing practices are minimal or nonexistent.
- Documentation and reporting are incomplete or lacking.
- Compliance and auditing efforts are sporadic and not systematically conducted.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic vulnerability disclosure, information sharing, and collaboration practices are established and documented.
- Initial efforts to develop and publish vulnerability disclosure policies are made.
- Basic reporting mechanisms and triage processes are implemented.
- Initial analysis, mitigation, and remediation processes are developed.
- Basic communication and coordination processes for internal and external stakeholders are established.
- Initial efforts to participate in information-sharing initiatives are made.
- Basic documentation and reporting practices are available.
- Initial compliance audits are conducted, but practices are not standardized.

- Initial efforts for continuous improvement are made.

Defined (3):

- Vulnerability disclosure, information sharing, and collaboration practices are comprehensively defined, documented, and communicated.
- Clear and accessible vulnerability disclosure policies are established and published.
- Comprehensive reporting mechanisms and systematic triage processes are in place.
- Formal analysis, mitigation, and remediation processes are established and consistently followed.
- Regular communication and coordination processes for internal and external stakeholders are in place.
- Active participation in information-sharing initiatives and industry collaboration is conducted.
- Comprehensive documentation and reporting practices are maintained.
- Regular compliance audits are conducted, and findings are addressed.
- Feedback loops and benchmarking are used to continuously improve practices.

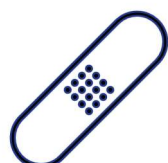
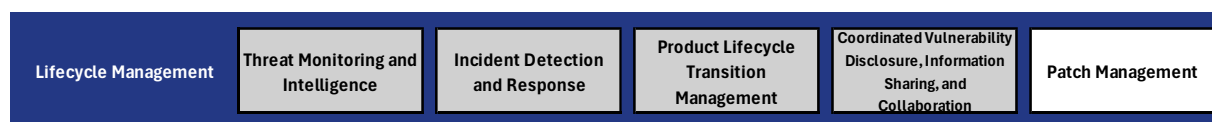
Managed (4):

- Metrics are established to monitor the effectiveness of vulnerability disclosure, information sharing, and collaboration practices.
- Quantitative techniques are used to understand and predict performance variations in disclosure and response efforts.
- Regular audits ensure adherence to vulnerability disclosure and information-sharing standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Vulnerability disclosure, information sharing, and collaboration practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize reporting, triage, analysis, and mitigation processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of vulnerability disclosure and information-sharing activities.

Patch Management



Patch management involves the systematic process of identifying, acquiring, testing, deploying, and monitoring software and firmware updates (patches) to mitigate security vulnerabilities and enhance system performance. Effective patch management ensures that systems remain secure, compliant, and functional throughout their lifecycle.

Scoring Criteria

Ad Hoc (1):

- Patch management practices are inconsistent and informal.
- Patch identification and acquisition processes are limited or lacking.
- Patch testing and evaluation processes are sporadic and not systematically conducted.
- Patch deployment efforts are reactive and inconsistent.
- Post-deployment validation and continuous monitoring are limited or lacking.
- Patch management policy and communication efforts are minimal or nonexistent.
- Documentation and reporting are incomplete or lacking.
- Compliance and auditing efforts are sporadic and not systematically conducted.
- Continuous improvement efforts are reactive and inconsistent.

Basic (2):

- Basic patch management practices are established and documented.
- Initial efforts to identify and acquire patches are made.
- Basic patch testing and evaluation processes are implemented.
- Initial patch deployment plans are developed, but practices are not standardized.
- Basic post-deployment validation and continuous monitoring processes are in place.
- Initial patch management policy and communication efforts are established.
- Basic documentation and reporting practices are available.
- Initial compliance audits are conducted, but practices are not standardized.
- Initial efforts for continuous improvement are made.

Defined (3):

- Patch management practices are comprehensively defined, documented, and communicated.
- Reliable sources for patch identification and acquisition are established and regularly reviewed.
- Comprehensive patch testing and evaluation processes are systematically conducted.
- Formal patch deployment plans, including automated deployment tools, are consistently applied.
- Systematic post-deployment validation and continuous monitoring processes are maintained.
- A comprehensive patch management policy is developed, communicated, and followed.
- Regular communication processes for internal and customer stakeholders are in place.
- Comprehensive documentation and reporting practices are maintained.
- Regular compliance audits are conducted, and findings are addressed.
- Feedback loops and benchmarking are used to continuously improve practices.

Managed (4):

- Metrics are established to monitor the effectiveness of patch management practices.
- Quantitative techniques are used to understand and predict performance variations in patch management.
- Regular audits ensure adherence to patch management standards.
- Continuous monitoring and validation processes are integrated into the overall security management framework.

Optimized (5):

- Patch management practices are continuously improved through regular monitoring and feedback loops.
- Advanced automation tools are used to optimize patch identification, testing, deployment, and monitoring processes.
- Statistical techniques are used to enhance the ability to achieve high-quality performance objectives.
- Continuous integration with other security management tools ensures real-time updates and monitoring of patch management activities.